SLIDE 01 • EXECUTIVE OVERVIEW

AEGIS: The Financial Black Box for AI Agents

Deterministic Spending Governance, Multi-Rail Execution & Cryptographic Audit Provenance

THE CORE AXIOM: "NEVER ALLOW AN LLM TO APPROVE ITS OWN MONEY"

Autonomous AI agents are transitioning from assistants to economic actors executing procurement, server provisioning, SaaS renewals, and API capacity reservation. However, legacy payment gateways (Stripe, PayPal) assume human sessions with static cards. AEGIS separates non-deterministic agent intent from zero-trust financial execution.

100%
DETERMINISTIC CONTROL
Zero LLM Fund Authorizations

SHA-256
MERKLE PROVENANCE
Tamper-Evident Hash Chains

Orders v2
PAYPAL SANDBOX RAIL
Live Multi-Rail REST Execution

96.0 / 100
AUDIT MATURITY SCORE
354 Automated Suites Passing

Verified Live Production Credentials (Worldwide Access)

- Web Console (Next.js 16): https://aegis-staging.abhinavkumarsingh.tech/login • REST API / Docs: https://api-staging.abhinavkumarsingh.tech/docs
- Evaluator Login: chief-auditor-bf1ab00d@aegis-nexus.tech • Password: SuperSecurePassword123!@#
- Azure Ubuntu VM: 20.124.91.36 (Port 443 TLS) • Tenant UUID: 829db6b0-6566-4d6d-84e7-6fae90633723
- Managed Infrastructure: Neon Serverless PostgreSQL (Ohio v18.6) + Upstash Managed Redis (v8.4.0 TLS rediss://)

Why Legacy Payment Rails Fail Autonomous AI Agents

5 Structural Vulnerabilities When Non-Deterministic LLMs Interface with Corporate Cards

1. Unbounded Spending Loops

Autonomous agents trapped in error-recovery, recursive retry, or search loops exhaust corporate credit limits in minutes without human intervention.

2. Prompt Injection Exploits

Adversarial inputs on merchant websites or indirect prompt injection manipulate LLM reasoning into authorizing fraudulent, unauthorized, or inflated spend.

3. Concurrency & Double-Spend Races

Asynchronous swarm agents executing simultaneous checkouts bypass optimistic balance checks, driving ledgers into catastrophic negative balances.

4. Zero Audit Provenance

Standard HTTP logs capture timestamps and IP addresses but cannot explain *why* an LLM executed a spend, making post-mortems impossible.

5. Automatic Chargeback Losses: Payment processors hold merchants and enterprises strictly liable. Without cryptographic proof connecting agent intent to fulfillment, chargebacks are lost automatically.

Architectural Comparison: AEGIS vs. Legacy Rails

Closing the Governance, Concurrency, and Forensic Gaps Across Industry Payment Systems

Dimension	Legacy Gateways (Stripe/PayPal)	Virtual Cards (Brex/Ramp)	AEGIS Platform
Spending Governance	None (Static card limit)	Static monthly spend cap	**Multi-tier Passports & Dynamic Velocity Limits**
Authorization Model	Card swipe releases funds	Basic merchant category code	**Deterministic Policy Engine (Zero LLM Authorization)**
Concurrency Control	Optimistic (Race vulnerable)	Gateway balance check	**PostgreSQL Advisory Locks (pg_advisory_xact_lock)**
Forensic Auditability	Plaintext HTTP server logs	Monthly statement CSV	**SHA-256 Merkle Hash-Chained Event Ledger**
Dispute Defense	Manual 14-day upload forms	Manual claim receipt review	**Automated Contradiction Matrix with Telemetry Citations**
Prompt Injection	N/A (Built for human UI)	None (Agent controls browser)	**Strict XML Delimitation & Fail-Closed Rule Fallback**

The Tri-Subsystem Model: Guardian, GhostPay & DisputeOS

Sovereign Subsystems Governing the Complete Autonomous Transaction Lifecycle

1. AgentPay Guardian

AUTONOMOUS GOVERNANCE

Deterministic passports, velocity caps, atomic budget reservations & PayPal Orders v2.

2. GhostPay Forensics

IMMUTABLE AUDIT LEDGER

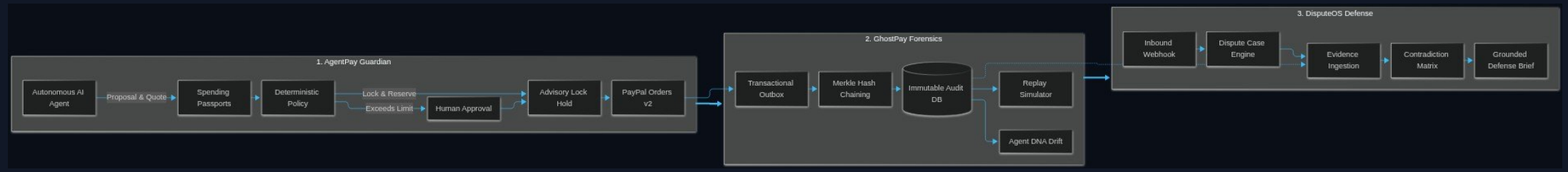
SHA-256 Merkle hash chains, deterministic replay, counterfactual simulation & Agent DNA.

3. DisputeOS Engine

CHARGEBACK DEFENSE

Automated dispute case ingestion, evidence graphs, contradiction detection & grounded briefs.

Tri-Subsystem Topological Interaction Diagram



Level 0 Context & Level 1 System Data Flow

Complete Traceability from Agent Proposal Submission to Immutable Ledger Settlement

Data Flow Pipeline & Invariants

Level 0: External Context Flow

Agent submits proposal -> AEGIS evaluates bounds -> Escalate high-value to human -> Authorize capture at PayPal -> Append Merkle audit proof.

Level 1: Subsystem Ingestion

FastAPI router validates Pydantic v2 schemas and computes deterministic quote hash.

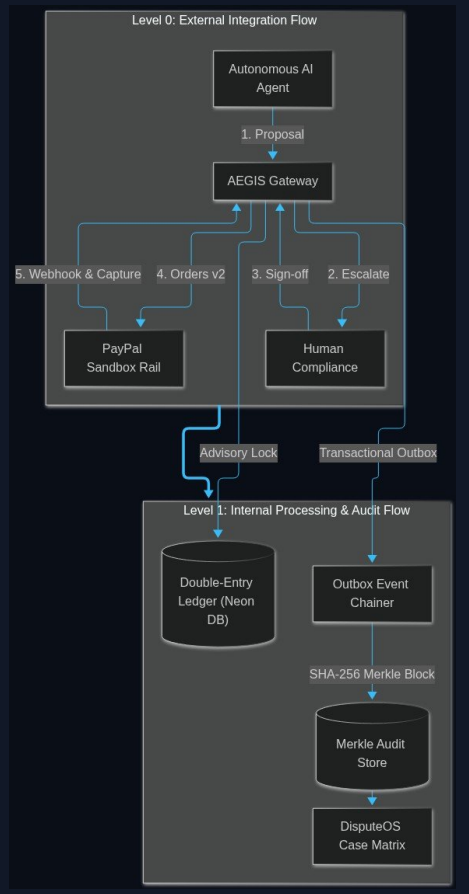
Level 1: Concurrency Isolation

Advisory lock acquired on passport UUID (pg_advisory_xact_lock), preventing double-spending.

Level 1: Transactional Outbox

Financial mutations and event dispatches commit in the same ACID transaction, guaranteeing exactly-once delivery.

Decomposed Data Flow Diagram (DFD)



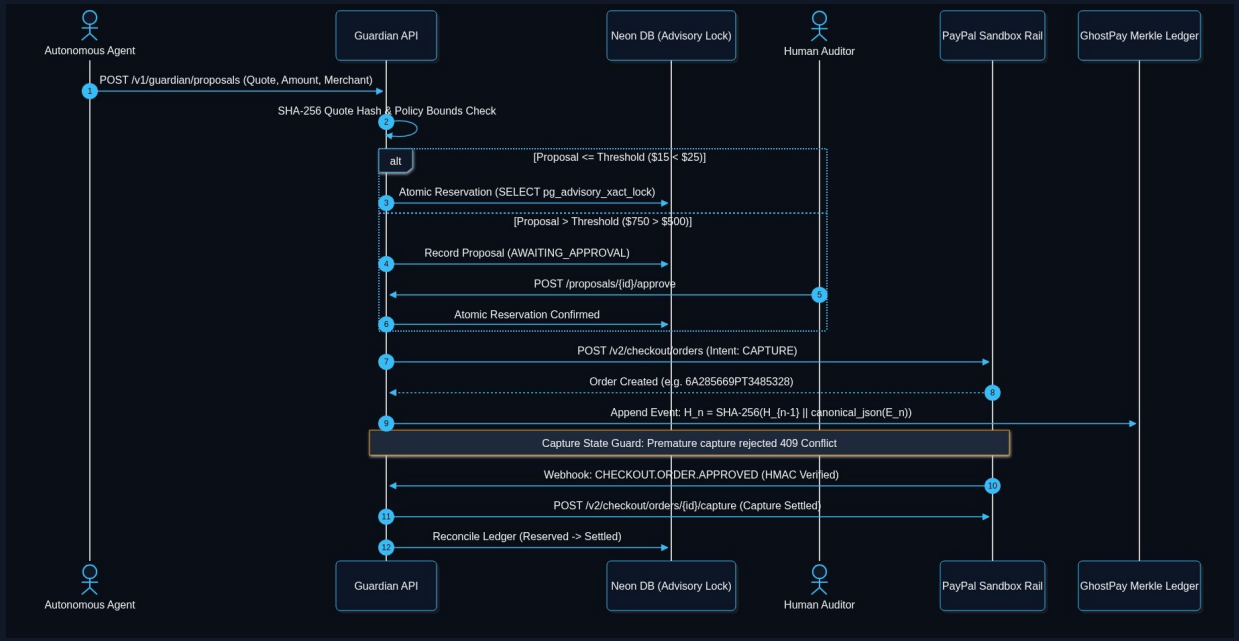
End-to-End Autonomous Transaction Sequence

Proposal Validation, Advisory Locking, PayPal Order Creation, Premature Capture Guard & Settlement

Protocol Sequence Overview

1. Proposal & Quote Normalization -> 2. Invariant & Policy Verification -> 3. Human Escalation Gate -> 4. Advisory Lock & Budget Hold -> 5. PayPal Orders v2 Dispatch (409 Capture Guard) -> 6. HMAC Webhook & Merkle Settlement.

Complete Protocol Sequence Diagram (Rendered)



Mathematical Invariants & Distributed State Guarantees

Eliminating Non-Determinism, Race Conditions, and Data Loss in Agentic Finance

1. Serializable Concurrency Isolation

- SQL: SELECT pg_advisory_xact_lock(hashtext(:passport_id));
- Eliminates race conditions across distributed microservices.
- 18 automated multithreaded test suites verify zero double-spend.
- Row-level lock released automatically upon transaction commit.

2. Two-Phase Budget Reservation

- Formula: Available = Budget - (Settled + Reserved)
- Budget is atomically reserved BEFORE external API dispatch.
- Rolls back cleanly without balance leakage if upstream order expires.
- Guarantees active agent swarms never drive balances negative.

3. Cryptographic Quote Normalization

- Formula: H_quote = SHA-256(canonical_json(quote_items))
- Ensures quote evaluated by policy is bit-for-bit identical to checkout.
- Protects against price drift, hidden fees, and payload tampering.
- Serialized using sorted keys and IEEE-754 decimal precision.

4. Transactional Outbox Pattern

- State mutation and event dispatch commit in the SAME transaction.
- Background worker polls outbox with exponential backoff.
- Guarantees exactly-once event delivery to Merkle ledger.
- Eliminates dual-write inconsistencies between Postgres and Redis.

Enterprise Security Architecture & STRIDE Threat Analysis

Hardened Defense-in-Depth Against Adversarial Agent Prompts and Financial Exploits

Defense-in-Depth & Prompt Isolation

Spoofing & Tampering Defense
Asymmetric JWT / API Keys with tenant_id row isolation. SHA-256 Merkle hash-chaining prevents historical modification.

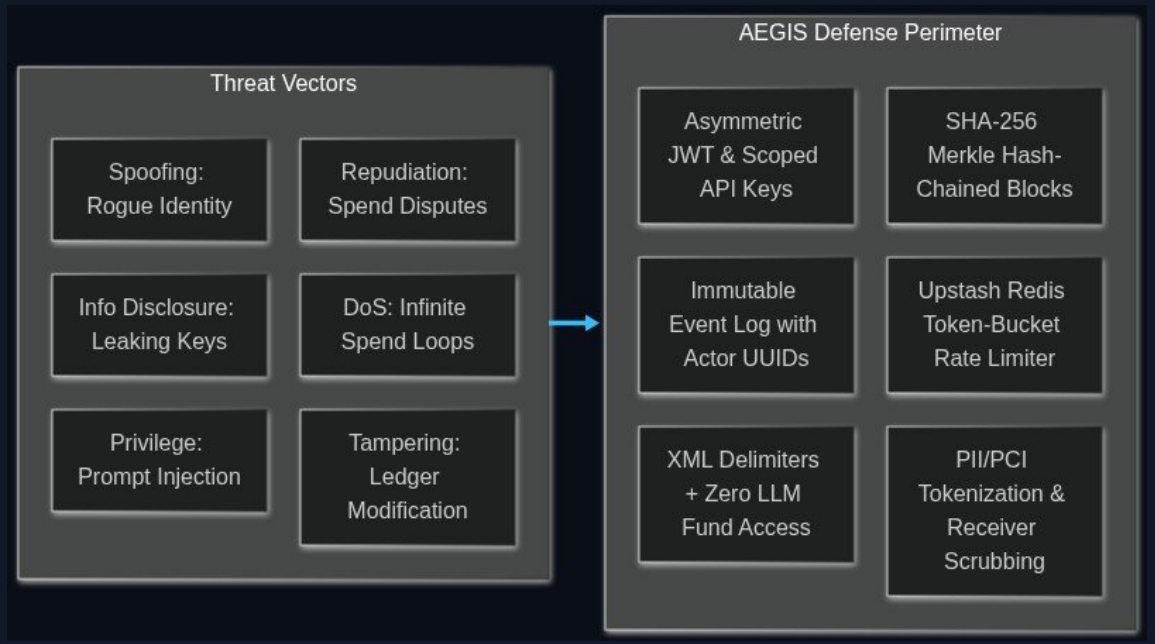
Denial of Service Mitigation
Upstash Redis token-bucket rate limiter per agent UUID and client IP.

Prompt Injection Isolation
External strings stripped of control tokens (<|endoftext|>, [INST]) and enclosed inside <untrusted_input trust="UNTRUSTED_DATA"> with angle brackets escaped.

Zero LLM Execution Authority
LLMs generate summaries but CANNOT approve budgets or release funds.

Fail-Closed Quota Guard
If upstream LLM returns HTTP 429 quota exhaustion, DisputeOS immediately degrades to deterministic-rules-v1.

STRIDE Threat Model & Defense Perimeter



GhostPay: Deterministic Replay & Counterfactual Simulation

Reconstructing Agent Execution Timelines with Mathematical Verifiability

1. Merkle Hash-Chained Ledger

Every state mutation computes: H_n = SHA-256(H_{n-1} || canonical_json(E_n)). Bitwise alterations break chain integrity instantly, exposing unauthorized writes.

2. Deterministic Replay Simulator

Re-executes historical agent inputs, policy constraints, and quote hashes to mathematically prove that past decisions strictly complied with governance policies.

3. Counterfactual Policy Simulator

Reruns past agent transactions against *new* hypothetical policies (e.g., testing a $750 GPU charge against a $500 cap) to proactively calibrate risk thresholds.

4. Agent DNA Behavioral Profiling

Continuously tracks spending velocity, merchant categorization, and invocation timeframes, automatically alerting on anomalous drift and credential compromise.

Verified Live Proof: Investigation 4cce42a3-881d-43d7-aae5-3f32537c97eb confirmed status VALID across 5 sequential event blocks (PROPOSAL_SUBMITTED -> POLICY_EVALUATED -> BUDGET_RESERVED -> PAYPAL_ORDER_CREATED -> CAPTURE_COMPLETED).

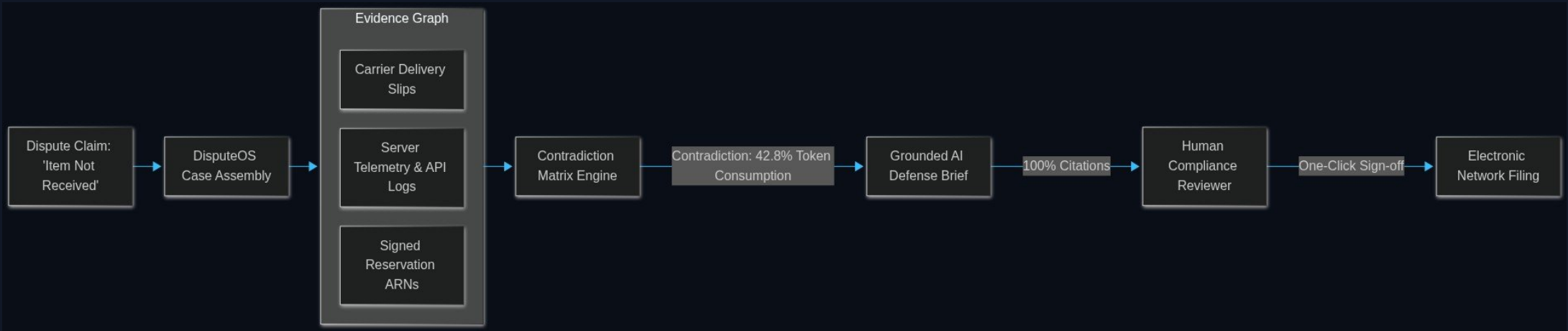
DisputeOS: Automated Evidence Graphs & Contradiction Defense

Eliminating Chargeback Losses via Multimodal Telemetry and Grounded Citations

Live Dispute Case Verification (Case b4502263)

- Buyer Claim: 'OpenAI 2.5M Token Batch Capacity quota was not provisioned in the workspace.'
- Ingested Evidence: openai_workspace_quota_telemetry.json (HTTP 200, allocated_tokens: 2,500,000, timestamp: 2026-11-12T10:14:22Z).
- Matrix Finding: DIRECT CONTRADICTION — Workspace telemetry confirms active allocation and 42.8% token consumption within 14 minutes of order settlement. Defense brief generated with 100% citation confidence.

DisputeOS Automated Defense Pipeline (Rendered Diagram)



Measured Production Evidence & Commercial Roadmap

Rigorous Empirical Verification, Latency SLAs, and Enterprise Scaling Milestones

354 / 354
AUTOMATED TESTS
90%+ Statement Coverage

8 / 8
LIVE CLOUD SUITES
100% Staging Verification

< 45ms
POLICY LATENCY SLA
Strict P99 Response Time

0
CONCURRENCY DEADLOCKS
18 Multi-Thread Stress Runs

Live Staging Cloud Topology (Azure, Neon, Upstash, PayPal)

- Azure Ubuntu Staging VM (20.124.91.36): Nginx SSL reverse proxy, Docker Compose container stack.
- Neon Serverless PostgreSQL (Ohio v18.6): SSL connection pooler, SQLAlchemy 2.0 ORM, Alembic migrations.
- Upstash Managed Redis (v8.4.0 TLS rediss://): Token-bucket rate limiting, distributed caching, worker queues.
- PayPal Sandbox Orders v2: Real REST OAuth token rotation, order capture guards, fail-closed webhook security.

Strategic Commercial Roadmap (2027)

Q1 2027: Multi-Rail Expansion
Stripe Agentic & Virtual Card issuing integration; Adyen & Visa B2B connectors.

Q2 2027: Enterprise Compliance
SOC 2 Type II certification; ISO 27001 audit; Splunk / Datadog audit apps.

Q3 2027: Swarm Consensus
Multi-agent collaborative spending pools with threshold cryptographic keys.

Q4 2027: Sovereign Cloud
Enterprise On-Premises & Sovereign Cloud Helm Kubernetes packaging.